

Tema 1. Ciberseguridad en las organizaciones

Idea clave 1. Justificación y motivación de la ciberseguridad

Microtest 1.1

1: El coste de realizar un ataque se denomina:

- a) Coste de ataque.
- b) Cost to break.
- c) Cost to fix.
- d) Coste de reconstrucción.

2: Para que la ciberseguridad sea rentable:

- a) Es difícilmente rentable.
- b) Coste construcción defensas < (cost to fix + pérdida de beneficio + coste reconstrucción).
- c) Cost to fix < (pérdida de beneficio).
- d) Cost to fix < (pérdida de reconstrucción).

3: Del lado de la organización, los costes básicos son: coste de construcción de las medidas defensivas, coste de reparación de vulnerabilidades y...

- a) Coste de reconstrucción de sistemas.
- b) Coste de ruptura.
- c) Coste de construcción.
- d) Ninguna de las anteriores.

Idea clave 2. Amenazas y riesgos de la ciberseguridad:

Microtest 1.2

1: Al tipo de protesta con fines de activismo político, social o económico en forma de ataques cibernéticos. (Anonymous, Wikileaks...), se la denomina:

- a) DDOS.
- b) Doxxing.
- c) Hacktivismo.
- d) Ninguna de las anteriores.

2: ¿Cuál es el ataque relacionado con los actores internos más frecuente?

- e) Phishing.
- a) DDOS.
- a) Troyano
- b) Hacktivismo.

3: Las APTs son características de:

- a) Actores internos.
- b) Actores estado.

Ciberseguridad Web

- c) Hacktivistas.
- d) Ninguna de las anteriores.

Idea clave 3. Dimensiones de la ciberseguridad

Microtest 1.3

1: ¿Cómo se puede asegurar la integridad de los sistemas?

- c) Validación de entrada.
- a) **Firma digital avanzada.**
- b) Autenticación.
- c) Ninguna de las anteriores.

2: ¿Para qué es necesario un correcto diseño de logging o registro?

- d) **Para garantizar la trazabilidad.**
- e) Para garantizar la confidencialidad.
- a) Para garantizar la integridad.
- b) Para garantizar la disponibilidad.

3: Proporcionar la prueba de que una determinada transmisión o recepción ha sido realizada, sin que su receptor/transmisor pueda negar que se haya producido, se denomina:

- c) Autenticar.
- d) Demostrar la identidad.
- a) Garantizar la integridad.
- b) **No repudio.**

Idea clave 4. La ciberseguridad es un proceso

Microtest 1.4

1: Las descripciones sobre cómo configurar determinados elementos de seguridad para que sean aplicados de manera uniforme en toda la organización se denominan:

- a) Política de seguridad.
- b) Directrices.
- c) **Líneas base.**
- d) Ninguna de las anteriores.

2: Las descripciones detalladas de los pasos para llevar a cabo una determinada tarea por los usuarios sin dudas se llaman:

- a) **Procedimientos.**
- b) Directrices.
- c) Líneas base.
- d) Ninguna de las anteriores.

3: Los estándares, directrices y procedimientos son medios para implementar las:

- a) Medidas de seguridad.

Ciberseguridad Web

- b) Líneas base.
- c) Políticas.
- d) Las opciones A y C.

Tema 2. Gestión de la ciberseguridad

Idea clave 1. Política de seguridad

Microtest 2.1

1: La política general de seguridad de una organización:

- a) Define el comportamiento apropiado para cada caso.
- b) Establece qué herramientas y qué procedimientos son necesarios.
- c) Sirve para comunicar un consenso del uso de datos y aplicaciones dentro de la organización.
- d) Todas las anteriores son correctas.

2: Un sistema de detección de intrusiones se usa en la fase de:

- a) Monitorización.
- b) Análisis de vulnerabilidades.
- c) Implementación.
- d) Monitorización y análisis de vulnerabilidades.

3: Un cortafuegos se instala en la fase de:

- a) Monitorización.
- b) Análisis de vulnerabilidades.
- c) Implementación.
- d) Ninguna de las anteriores.

Idea clave 2. Diseño de la política de seguridad

Microtest 2.2

1: El tipo de norma que estandariza el uso de aspectos específicos del sistema (indican un uso correcto y responsabilidad del usuario y son obligatorias) se denomina:

- a) Procedimientos de seguridad.
- b) Estándar.
- c) Guía de seguridad.
- d) Ninguna de las anteriores.

2: El tipo de norma destinada a ayudar a los usuarios a aplicar las medidas de seguridad correctamente al proporcionar un razonamiento donde no se dispone de los procedimientos correctos, se denomina:

- a) Procedimientos de seguridad.
- b) Estándar.
- c) Guía de seguridad.

Ciberseguridad Web

d) Ninguna de las anteriores

3: El tipo de norma que se ocupa de tareas específicas, mostrando cada paso que se debe realizar y que es muy útil en tareas que son repetitivas, como en un procedimiento de backup y recuperación, se denomina:

- a) Procedimientos de seguridad.
- b) Estándar.
- c) Guía de seguridad.
- d) Ninguna de las anteriores.

Idea clave 3. Sistema de gestión de seguridad de la información

Microtest 2.3

1: Un sistema de gestión para la seguridad de la información:

- a) Establece o planifica la seguridad de la información.
- b) Opera y mantiene los procesos establecidos para la seguridad de la información.
- c) Mide los resultados (monitorización) e indicadores de los distintos procesos de la seguridad de la información.
- d) Todas las anteriores son correctas.

2: ¿Cuál es la actividad más importante en un SGSI?

- a) Planificación.
- b) Elaborar procedimientos.
- c) Análisis y gestión de riesgos.
- d) Ninguna de las anteriores.

3: La declaración de aplicabilidad de salvaguardas es propia de la fase (ISO27001):

- a) ACT: Mejora.
- b) PLAN: análisis de riesgos.
- c) PLAN: tratamiento de los riesgos.
- d) Ninguna de las anteriores.

Idea clave 4. Profesión de gestión de la ciberseguridad

Microtest 2.4

1: Una profesión puede caracterizarse por el desarrollo de algunos de los siguientes criterios:

- a) La creación de un cuerpo organizado de conocimientos.
- b) El reconocimiento por parte de los clientes de la autoridad de la profesión.
- c) La aprobación de la comunidad de la autoridad de la profesión.
- d) Todas las anteriores son ciertas.

Ciberseguridad Web

2: El hacker ético tiene como elemento interesante el situar:

- a) La seguridad desde el contexto defensivo.
- b) La seguridad desde el contexto del atacante.
- c) La seguridad tanto desde el contexto del atacante como desde el contexto de defensa.
- d) Todas las anteriores son correctas

3: Un ejemplo de recopilación de requisitos en el área (que puede considerarse como definitorio) de qué debe saber un profesional de la seguridad de la información sería:

- a) El decálogo OWASP.
- b) No existen recopilaciones de requisitos adecuadas actualmente.
- c) El cuerpo de conocimiento (body of knowledge, BOK) del Consorcio Internacional de Certificación de Seguridad de Sistemas de Información o (ISC)2.
- d) Todas las anteriores son correctas

Idea clave 5. Certificaciones de ciberseguridad

Microtest 2.5

1: La certificación Certified Information Systems Security Professional (CISSP) es certificada por:

- a) SANS.
- b) ISACA.
- c) Certification and Accreditation Professional.
- d) International Information Systems Security Certification Consortium.

2: La certificación Certified Information Systems Security Professional (CISSP), incluye:

- a) Information Systems Security Architecture Professional (CISSP-ISSAP).
- b) Information Systems Security Engineering Professional (CISSP-ISSEP).
- c) Information Systems Security Management Professional (CISSP-ISSMP).
- d) Todas las anteriores son correctas

3: Un CISSP está certificado como profesional para:

- a) Definir la arquitectura de seguridad.
- b) Desarrollar software seguro.
- c) Realizar auditorías de seguridad exclusivamente.
- d) Todas las anteriores son correctas.

Tema 3. Análisis y gestión de riesgos de ciberseguridad

Idea clave 1. Principales metodologías y herramientas

Microtest 3.1

1: ¿Cuál es una desventaja de OCTAVE?

- a) No establece explícitamente la identificación de vulnerabilidades como uno de los pasos de la metodología.
- b) La flexibilidad.
- c) **Implica un elevado nivel de conocimientos tecnológicos y técnicos.**
- d) A y B son correctas.

2: ¿Cuál es la principal desventaja de MAGERIT?

- a) **No establece explícitamente la identificación de vulnerabilidades como uno de los pasos de la metodología.**
- b) Facilidad a la hora de traducir una estimación cualitativa a una cuantía económica.
- c) Implementación.
- d) Las opciones A y B son correctas.

3: MAGERIT está basada en las normas:

- a) ISO 27001.
- b) ISO 27002.
- c) ISO 27005.
- d) **Todas las anteriores son correctas.**

Idea clave 2. Planificación de un proyecto de análisis de riesgos

Microtest 3.2

1: ¿En qué fase se realiza la toma de decisiones?

- a) Planificación.
- b) **Gestión de riesgos.**
- c) Análisis de riesgos.
- d) Todas las anteriores son correctas.

2: En el comité de dirección existe la figura del:

- a) Director del proyecto.
- b) Enlace de seguimiento.
- c) Interlocutor.
- d) **Promotor.**

3: El director del proyecto y su equipo planifican toda la realización del proyecto a través de:

- a) Plan de entrevistas que realizar.
- b) Participantes que entrevistar.
- c) Calendario.

Ciberseguridad Web

- d) Todas las anteriores son correctas.

Idea clave 3. Análisis de riesgos

Microtest 3.3

1: El impacto es igual a:

- a) Valor por riesgo acumulado.
- b) Degradación del valor del activo.
- c) Riesgo acumulado por frecuencia.
- d) Ninguna de las anteriores.

2: El actor o agente que es la fuente de peligro por diferentes motivaciones como factores económicos, de prestigio u otros, se denomina:

- a) Vulnerabilidad.
- b) Activo.
- c) Amenaza.
- d) Ataque.

3: ¿Cómo hay que valorar una salvaguarda?

- a) Según el coste económico.
- b) De forma cualitativa.
- c) En base a su eficacia medida en cómo la salvaguarda está implantada.
- d) Ninguna de las anteriores.

Idea clave 4. Gestión de riesgos

Microtest 3.4

1: ¿Cuál es la solución ideal para mitigar el riesgo?

- a) Evitarlo.
- b) Reducirlo, mitigarlo. Se limita el impacto.
- c) Transferirlo a otra organización.
- d) Asumirlo. Pasa a contabilizarse como gasto operacional.

2: Debe haber un programa de seguridad para:

- a) La organización.
- b) Cada fase del proyecto.
- c) Cada escenario de impacto para dar respuesta.
- d) Cada servicio.

3: Los aspectos que definen la gestión del riesgo son:

- a) Su objetivo genérico.
- b) Las salvaguardas concretas que implantar o mejorar, detallando sus objetivos de calidad, eficacia y eficiencia.

Ciberseguridad Web

- c) La relación de escenarios de impacto o riesgos que afronta: activos afectados, tipos de activos, amenazas afrontadas, valoración de activos y amenazas y niveles de impacto y riesgo.
- d) **Todas las anteriores son correctas.**

Idea clave 5. Herramienta PILAR

Microtest 3.5

1: La fase de análisis de riesgos con PILAR comparta las siguientes actividades:

- a) Se identifican y valoran todos los activos implicados.
- b) Se identifican y valoran las amenazas del sistema.
- c) Se identifica y se valora la efectividad de las salvaguardas.
- d) **Todas las anteriores son correctas.**

2: Señale la respuesta correcta. El coste de las salvaguardas debe ser inferior a:

- a) 10 % del valor del sistema a proteger.
- b) Los beneficios.
- c) **La estimación de las pérdidas.**
- d) Ninguna de las anteriores.

3: Los perfiles de seguridad que incorpora la herramienta PILAR son:

- a) ISO 27002:2013.
- b) GDPR.
- c) ENS.
- d) **Todas las anteriores son ciertas.**

Tema 4. Seguridad en aplicaciones web. Introducción

Idea clave 1. Ciclo de vida de desarrollo seguro de software (SSDLC)

Microtest 4.1

1: ¿En qué fase se debe realizar un test de penetración a una app web?

- a) Diseño.
- b) Desarrollo.
- c) **Pruebas.**
- d) Producción.

2: La derivación de requisitos de seguridad depende de:

- a) El modelado de amenazas o casos de abuso.
- b) Del análisis de riesgos.
- c) Análisis de seguridad del código fuente.
- d) **Las opciones A y B.**

3: Antes del test de penetración, ¿qué actividades de seguridad hay que llevar a cabo?

- a) Derivación de requisitos de seguridad.

Ciberseguridad Web

- b) Modelado de amenazas.
- c) Análisis de seguridad del código fuente.
- d) Todas las opciones anteriores son correctas.

Idea clave 2. Arquitecturas de las aplicaciones web clásicas

Microtest 4.2

1: Los web services son un tipo de arquitectura:

- a) Clásica.
- b) RIA.
- c) SOA.
- d) Ninguna de las anteriores.

2: ¿Qué tipo de aplicaciones móviles tienen más limitado el acceso a los dispositivos físicos del móvil?

- a) Nativas.
- b) Basadas en navegador.
- c) Híbridas.
- d) Clásicas.

3: En la arquitectura clásica de aplicaciones web, ¿Dónde se genera la capa de presentación?

- a) Navegador.
- b) Persistencia.
- c) Servidor de aplicaciones.
- d) SGBD.

Idea clave 3. Arquitecturas de las aplicaciones web AJAX

Microtest 4.3

1: ¿Qué método se suele usar en las arquitecturas de aplicaciones AJAX para comunicación con el servidor?

- a) Request().
- b) HttpRequest().
- c) xmlRequest().
- d) xmlhttpRequest().

2: ¿Qué tecnologías usa la arquitectura de aplicaciones AJAX?

- a) JavaScript.
- b) XML.
- c) HTML.
- d) Todas las anteriores son correctas.

Ciberseguridad Web

3: En la arquitectura RIA de aplicaciones web, ¿dónde se genera la capa de presentación?

- a) **Navegador.**
- b) Persistencia.
- c) Servidor de aplicaciones.
- d) SGBD.

Idea clave 4. Protocolo HTTP

Microtest 4.4

1: ¿Qué método HTTP permite conectarse a un servicio situado detrás de un proxy?

- a) PUT.
- b) GET.
- c) POST.
- d) **CONNECT.**

2: ¿Qué método HTTP permite obtener solo las cabeceras de la aplicación web?

- a) PUT.
- b) **HEAD.**
- c) POST.
- d) GET.

3: ¿Qué método HTTP envía los parámetros en la URL?

- a) **GET.**
- b) POST.
- c) PUT.
- d) Todas las anteriores.

Tema 5. Vulnerabilidades en las aplicaciones web

Idea clave 1. Vulnerabilidades OWASP Top Ten 2021: XSS, SQLI

Microtest 5.1

1: ¿Cómo se previene XSS?

- a) Test de penetración.
- b) Codificación de la salida.
- c) Validación de entrada mediante consultas parametrizadas.
- d) **B y C son correctas.**

2: ¿Qué vectores de entrada se pueden usar para intentar XSS?

- a) Enlaces de correos electrónicos.
- b) Campos de formularios.
- c) Cualquier ejecución de un enlace debidamente parametrizado desde cualquier ubicación.

Ciberseguridad Web

- d) Todas las anteriores son correctas

3: ¿Cuál es un ejemplo de payload XSS?

- a) `<script>alert("hacked")</script>`.
- b) `' OR 1=1#`.
- c) `C../../template.ini`.
- d) Todas las anteriores.

Idea clave 2. Vulnerabilidades OWASP Top Ten 2021: HTTP RESPONSE SPLITTING, LFI, RFI

Microtest 5.2

1: La vulnerabilidad LFI o inclusión de ficheros...

- a) Permite acceder a recursos del sistema de ficheros no permitidos.
- b) Permite autenticarse suplantando a un usuario.
- c) Permite robo de credenciales.
- d) Las opciones A y C son correctas.

2: ¿Qué vectores de entrada se pueden usar para intentar explotar LFI?

- a) Enlaces de correos electrónicos.
- b) Campo de un formulario.
- c) Todas las opciones son correctas.
- d) Cualquier ejecución de un enlace debidamente parametrizado desde cualquier ubicación.

3: ¿Cuál es un ejemplo de payload de RFI?

- a) `<script>alert("hacked")</script>`.
- b) `' OR 1=1#`
- c) `C../../template.ini`
- d) `http://localhost/index.php?page = http://google.com/`.

Idea clave 3. Vulnerabilidades OWASP Top Ten 2021: HARDCODED PASSWORD, SESSION FIXATION, SSRF

Microtest 5.3

1: ¿Por qué motivo se puede dar un ataque de suplantación en una aplicación web mediante fijación de sesión?

- a) La aplicación web suministra un ID de sesión previo a la autenticación correcta de un usuario.
- b) Suplantar a un usuario no es posible a menos que se capture el ID de sesión.

Ciberseguridad Web

- c) La aplicación web suministra un ID de sesión después de una autenticación correcta de un usuario.
- d) Todas las anteriores son ciertas.

2: ¿Cómo se puede conseguir explotar Server Side Request Forgery?

- a) Manipulación de parámetros a través de un formulario.
- b) Ejecutando un enlace contenido en un correo recibido.
- c) Ejecutando un enlace navegando por Internet.
- d) Todas las anteriores son correctas.

3: ¿Cómo se puede mitigar la vulnerabilidad Server Side Request Forgery?

- a) Consultas parametrizadas.
- b) Validación de entrada.
- c) Codificación de la salida.
- d) Ninguna de las anteriores.

Idea clave 4. Vulnerabilidades OWASP Top Ten 2013: CSRF y Open Redirect Microtest 5.4

1: ¿Cómo se previene CSRF?

- a) Test de penetración.
- b) Codificación de la salida.
- c) Validación de entrada mediante consultas parametrizadas.
- d) Token anti-CSRF.

2: La vulnerabilidad redirección no validada (open redirect):

- a) Permite incluir ficheros remotos de otro servidor no permitidos.
- b) Permite autenticarse suplantando a un usuario.
- c) Permite el robo de credenciales.
- d) Permite redirigir al usuario víctima a un sitio web no esperado.

3: ¿Cuál es un ejemplo de payload de CSRF?

- a) `<script>alert("hacked")</script>`.
- b) `' OR 1=1#`.
- c) `C../../template.ini`.
- d) Ninguna de las anteriores.

Tema 6. Autenticación en las aplicaciones web

Idea clave 1. Autenticación HTTP BASIC –DIGEST

Microtest 6.1

1: ¿Cómo envía el método Basic las credenciales al servidor de aplicaciones?

- a) Cifrados.
- b) En claro.
- c) Codificadas Base64.
- d) HASH MD5.

2: ¿Qué ataques puede sufrir Basic?

- a) Repetición.
- b) XSS.
- c) CSRF.
- d) RFI.

3: ¿Cómo envía Digest las credenciales al servidor de aplicaciones?

- a) Cifrados.
- b) En claro.
- c) Codificadas en Base64.
- d) HASH MD5.

Idea clave 2. Autenticación NTLM – KERBEROS

Microtest 6.2

1: ¿Cómo envía NTLM las credenciales al servidor de aplicaciones?

- a) Cifrados.
- b) HMAC-MD5.
- c) Codificadas en Base64.
- d) HASH MD5.

2: ¿Qué ataque es típico contra Kerberos?

- a) Golden Ticket.
- b) Silver Ticket.
- c) Kerberoasting.
- d) Todas las anteriores son correctas.

3: NTLM calcula 2 parámetros que son:

- a) LMV2 y NTV2.
- b) LMV2 y TNV2.

Ciberseguridad Web

- c) Solo calcula y envía NTV2.
- d) Todas las anteriores son correctas.

Idea clave 3. Autenticación OAUTH2 OPENID CONNECT

Microtest 6.3

1: OAUTH2 usa:

- a) Token de acceso.
- b) Código de autorización.
- c) La A y la B.
- d) Ticket.

2: ¿De qué tipo son el token y el código de autorización en OAUTH2?

- a) DIGEST.
- b) BASIC.
- c) JWT.
- d) HTTP.

3: ¿Dónde se aloja la información del usuario en un JWT?

- a) HEADER.
- b) PAYLOAD.
- c) SIGNATURE.
- d) Todas las anteriores son correctas.

Idea clave 4. Autenticación TLS -BASADA EN FORMULARIOS

Microtest 6.4

1: TLS usa algoritmos como:

- a) RSA.
- b) AES.
- c) SHA-512
- d) Todos los anteriores son correctos.

2: La autenticación basada en formularios hace uso de:

- a) Método HTTP POST.
- b) ID de sesión.
- c) Usuario y contraseña.
- d) Todas las anteriores son correctas.

Ciberseguridad Web

3: ¿Qué se recomienda para TLS?

- a) Además de comprobar el certificado del servidor, requerir la comprobación de un certificado personal al cliente.
- b) Usar AES 256.
- c) Usar RSA 2048.
- d) Todas las anteriores son correctas.

Idea clave 5. Autenticación: Recomendaciones

Microtest 6.5

1: ¿Qué tipo de ataques puede sufrir la autenticación para suplantar un usuario?

- a) Fuerza bruta.
- b) LFI.
- c) SSRF.
- d) Todos los anteriores son correctos.

2: ¿De qué tipo de ataque previene la implementación de CAPTCHA?

- a) Fuerza bruta.
- b) LFI.
- c) SQLI.
- d) XSS.

3: ¿Qué medidas se recomiendan para implementar para tener una autenticación más robusta?

- a) Comprobar ruta de certificación en TLS: certificate pinning.
- b) Combinar distintos métodos de autenticación (algo que se sabe, se tiene o se es).
- c) TLS de cliente requerido para combinar con todos los demás métodos.
- d) Todas las anteriores son correctas.

Tema 7. Gestión de sesiones y autorización en las aplicaciones web

Idea clave 1. Gestión de sesiones

Microtest 7.1

1: ¿Cuándo se debe crear el ID de sesión?

- a) Antes de la autenticación.
- b) Después de la autenticación correcta.
- c) En cualquier momento.
- d) No es necesario.

Ciberseguridad Web

2: ¿Dónde puede ubicarse el ID de sesión?

- a) Cabecera SET-COOKIE.
- b) Parámetro URL.
- c) Parámetro POST.
- d) Todas las anteriores.

3: ¿Con qué método de autenticación se crea el ID de sesión?

- a) NTLM.
- b) BASIC.
- c) Basado en formularios.
- d) DIGEST.

Idea clave 2. Autorización

Microtest 7.2

1: ¿Cómo se denomina la base de datos del mecanismo de autorización?

- a) Lista de control de acceso.
- b) Base de datos.
- c) Roles.
- d) Recursos.

2: ¿Con qué tipo de usuario se ejecuta un proceso relativo a un sitio web o plugin del navegador?

- a) Con un usuario cualquiera del sistema operativo.
- b) Con el usuario del navegador.
- c) Con un token restringido.
- d) Ninguna de las anteriores.

3: ¿Qué se comprueba en la lista de control de acceso para permitir el acceso a un recurso a un usuario?

- a) Si el usuario posee el rol necesario que requiere el recurso para ser accedido.
- b) Si es administrador.
- c) Si es administrador no se realizan comprobaciones en la lista de control de acceso.
- d) Ninguna de las anteriores.

Ciberseguridad Web

Idea clave 3. Autorización: Recomendaciones

Microtest 7.3

1: ¿Cuál es un ataque a la autorización?

- a) TOCTOU.
- b) XSS.
- c) LFI.
- d) Todos los anteriores.

2: ¿Cuál de los siguientes es un mecanismo de defensa para una buena autorización?

- a) Política robusta de contraseñas.
- b) Separación de roles y tareas.
- c) Administración robusta de permisos.
- d) Todas las anteriores.

3: ¿A qué se debe el TOCTOU?

- a) A no diseñar operaciones atómicas.
- b) A no bloquear el acceso a los recursos debidamente.
- c) A no tener un identificador de sesión largo.
- d) Las opciones A y B son correctas.

Tema 8. Seguridad en el desarrollo de las aplicaciones web

Idea clave 1. Principios del desarrollo seguro

Microtest 8.1

1: ¿Qué no hay que usar para identificar usuarios?

- a) Direcciones de correo electrónico.
- b) Nombres de usuario usando abreviaturas del nombre y apellidos
- c) Opciones A y D.
- d) Direcciones IP, MAC.

2: Señala la afirmación incorrecta sobre buenas prácticas de programación:

- a) Rehusar código que ha sido testeado y probado.
- b) Usar listas negras en lugar de blancas de comprobación.
- c) Revisar el proceso de mantenimiento.
- d) Insistir en el proceso de revisión de código.

3: Señalar la afirmación incorrecta sobre buenas prácticas de programación:

- a) No usar en el código nombres relativos de ficheros.
- b) No invocar programas en los que no se confía desde programas en los que se confía.

Ciberseguridad Web

- c) Asumir que los usuarios no son maliciosos.
- d) Utilizar librerías seguras que generan números aleatorios como random.

Idea clave 2. Desarrollo seguro: OWASP Top Ten I

Microtest 8.2

1: La mejor forma de evitar SQL injection es:

- a) Utilizando blacklist antes que whitelist.
- b) Validando en el lado del cliente.
- c) Mediante sentencias preparadas de SQL.
- d) Ninguna de las anteriores.

2: ¿Cuáles son formas de prevención de XSS en el código?

- a) Validación de entrada.
- b) Codificación de la salida.
- c) Cabecera XSS-protection y Content Security Policy.
- d) Todas las anteriores son correctas.

3: ¿Cuáles son las formas de prevención de HTTP response splitting en el código?

- a) Validación de entrada para evitar los caracteres CR LF.
- b) Codificación de la salida.
- c) Validación de lista negra.
- d) Todas las anteriores son ciertas.

Idea clave 3. Desarrollo seguro: OWASP Top Ten II

Microtest 8.3

1: ¿Cómo se pueden evitar vulnerabilidades XXE?

- a) Validando los datos de entrada en el código fuente.
- b) Validando los datos de entrada a través del XSD.
- c) No admitiendo definiciones DTD.
- d) Todas las anteriores son ciertas.

2: ¿Qué se recomienda a la hora de generar números aleatorios?

- a) Usar algoritmos de tipo estadístico.
- b) Usar algoritmos de tipo criptográfico.
- c) Cualquier número lo suficientemente largo > de 14 caracteres es válido.
- d) Todas las anteriores son ciertas.

3: ¿Cómo se denomina en Java la función segura de generación de números aleatorios?

Ciberseguridad Web

- a) SecRandom().
- b) SecureRandom().
- c) Random().
- d) Ninguna de las anteriores.

Idea clave 4. Desarrollo seguro: OWASP Top Ten III

Microtest 8.4

1: Señalar la afirmación incorrecta:

- a) No existe inconveniente, desde el punto de vista de la seguridad, en llamar librerías de terceros desde nuestro código, ya que se estima que son seguras.
- b) El código de terceros y el propio pueden contener vulnerabilidades públicas CVE.
- c) Es necesario comprobar las dependencias de software de terceros para verificar las posibles CVE.
- d) No se puede afirmar una seguridad del 100 % en un código.

2: ¿Cómo no se debe acceder (mediante autenticación) a una base de datos desde el código?

- a) Solicitando user/password al usuario desde la consola y verificar contra la almacenada en una BB.DD.
- b) Codificando user/password en el código fuente.
- c) Solicitando user/password al usuario desde la consola y verificar contra la almacenada en un fichero protegido.
- d) Todas las anteriores son ciertas.

3: ¿Qué función hay que usar en lugar de eval()?

- a) innerhtml().
- b) innertext().
- c) json.parse().
- d) Las herramientas IAST pueden detectar únicamente, bloquear o sanear la petición.

Idea clave 5. Desarrollo seguro: Open redirect y CSRF

Microtest 8.5

1: Señalar la afirmación correcta para evitar Open Redirect:

- a) Se debe usar sentencias parametrizadas.
- b) Se debe codificar la salida.
- c) Se debe usar una validación de lista blanca.
- d) Se debe usar una validación en el lado cliente.

Ciberseguridad Web

2: Señalar la afirmación correcta para evitar CSRF:

- a) Se debe usar un token anti CSRF.
- b) Se debe codificar la salida.
- c) Se debe usar una validación de lista blanca.
- d) Se debe usar una validación en el lado cliente.

3: ¿A qué corresponde la siguiente línea de código?:

`req.getParameter("_csrf_token").equals(req.getSession().getAttribute("_csrf_token"))`.

- a) Al uso de sentencias parametrizadas de SQL.
- b) Al uso de un identificador de sesión.
- c) A la comprobación de un token anti SSRF.
- d) A la comprobación de un token anti CSRF.

Tema 9. Análisis de seguridad de las aplicaciones web

Idea clave 1. Análisis de seguridad de las aplicaciones web

Microtest 9.1

1: ¿En qué fase del SSDLC se debe usar una herramienta SAST?

- a) Diseño.
- b) Desarrollo.
- c) Producción.
- d) Pruebas.

2: ¿En qué fase del SSDLC se debe usar una herramienta DAST?

- a) Diseño.
- b) Desarrollo.
- c) Producción.
- d) Pruebas.

3: ¿En qué fase del SSDLC se debe usar una herramienta IAST?

- a) Diseño.
- b) Desarrollo.
- c) Producción.
- d) Pruebas.

Idea clave 2. Análisis de seguridad estático de código fuente

Microtest 9.2

Ciberseguridad Web

1: ¿Qué tipo de análisis puede realizar una herramienta SAST para comprobar las interacciones entre distintas funciones?

- a) Intraprocedural.
- b) Interprocedural.
- c) Semántico.
- d) Todos los anteriores.

2: En cuanto a herramientas de análisis de la seguridad SAST, señalar la afirmación falsa:

- a) Cubren todo el código de la aplicación excepto las dependencias de terceros.
- b) Tienen falsos negativos y falsos positivos.
- c) Algunas pueden analizar código ejecutable.
- d) Todas las anteriores son falsas.

3: ¿Qué se puede hacer con los falsos positivos posibles en el resultado de análisis de una herramienta SAST?

- a) Auditar las vulnerabilidades del informe.
- b) No es necesario hacer nada puesto que realmente no son vulnerabilidades.
- c) Este tipo de herramientas no tienen falsos positivos.
- d) Todas las anteriores son ciertas.

Idea clave 3. Análisis de seguridad funcional y dinámico

Microtest 9.3

1: Señalar la afirmación falsa:

- a) Las herramientas de análisis de tipo IAST no suelen tener falsos positivos.
- b) Las herramientas RASP se pueden utilizar como firewalls de aplicaciones web de tipo software.
- c) Las herramientas de tipo IAST normalmente no tienen impacto en el rendimiento.
- d) Las herramientas IAST obtienen un informe del análisis de vulnerabilidades.

2: Las herramientas de tipo IAST pueden instrumentar:

- a) El código fuente.
- b) Las peticiones y respuestas.
- c) El código ejecutable.
- d) Ninguna de las anteriores.

3: ¿Qué tipo de análisis realiza una herramienta de tipo DAST?

- a) Semántico.
- b) Sintáctico.
- c) Interprocedural

Ciberseguridad Web

- d) Intraprodedural.

Tema 10. Seguridad en la fase de producción de las aplicaciones web

Idea clave 1. Firewall de aplicaciones web

Microtest 10.1

1: Un WAF detecta y bloquea ataques web usando:

- a) Expresiones regulares.
- b) Análisis semántico.
- c) No bloquea ataques.
- d) Ninguna de las anteriores.

2: ¿Qué tipo de instalación de un WAF solo detecta y no bloquea un ataque?

- a) Bridge.
- b) Proxy reverso.
- c) Pasivo.
- d) Ninguna de las anteriores.

3: ¿Qué tipo de instalación es la más recomendable para un WAF?

- a) Bridge.
- b) Proxy reverso.
- c) Pasivo.
- d) Ninguna de las anteriores.

Idea clave 2. Cabeceras de seguridad HTTP

Microtest 10.2

1: ¿Qué valor se recomienda para la cabecera X-FRAME-OPTIONS?

- a) STRICT.
- b) HTTPONLY.
- c) LAX.
- d) DENY.

2: ¿Qué valor se recomienda para la cabecera CONTENT-SECURITY-POLICY?

- a) default-src 'self'.
- b) same origin.
- c) strict.
- d) *.

Ciberseguridad Web

3: ¿Qué valor se recomienda para el parámetro SAME SITE de la cabecera SET-COOKIE?

- a) **STRICT.**
- b) HTTPONLY.
- c) LAX.
- d) DENY.

Idea clave 3. Seguridad en aplicaciones RIA

Microtest 10.3

1: La vulnerabilidad XSS DOM se puede evitar mediante:

- a) Codificación de la salida.
- b) Validación de entrada.
- c) Cabecera XSS-PROTECTION.
- d) **Todas las anteriores son correctas.**

2: El ataque Javascript hijacking es similar en tecnología AJAX a:

- a) XSS-DOM.
- b) **CSRF.**
- c) SQLI.
- d) Ninguna de las anteriores.

3: ¿Cómo se puede saltar/evitar la política del mismo origen?

- a) <script>...</script>.
- b) <iframe>...</iframe>.
- c)
- d) **Todas las anteriores son correctas.**